i-Ticket

YOUR JOURNEY, SIMPLIFIED

SECURITY AUDIT — TECHNICAL RESUBMISSION

Web Application Security Assessment

Consolidated technical resubmission for INSA cybersecurity compliance audit

Request ID: ICAER-2026-E391DA • February 2026

PREPARED FOR

Information Network Security Administration (INSA)

Cyber Security Audit Division

APPLICATION
i-Ticket Online Bus Ticketing Platform

VERSION
v2.14.5

PRODUCTION URL
https://i-ticket.et

SUBMISSION DATE
February 2026

REQUEST ID
ICAER-2026-E391DA

CLASSIFICATION
Confidential

Confidential — INSA Audit Use Only. This document contains proprietary security architecture details, API endpoint maps, authentication mechanisms, and system configuration for the i-Ticket platform. Distribution is restricted to authorized INSA audit personnel only.

1. Application Overview

1.1 Purpose and Scope

i-Ticket is an **online bus ticket booking platform** for Ethiopian inter-city bus travel. It enables passengers to search trips, book seats, pay via TeleBirr mobile money, and receive QR-coded tickets. Bus companies use the platform to manage trips, staff, fleet, and manifests. The platform also includes real-time GPS bus tracking, a Telegram bot for bilingual booking, predictive fleet maintenance, and a no-show management system.

1.2 Technology Stack

Layer	Technology
Runtime	Node.js 20.20.0
Framework	Next.js 14 (App Router, TypeScript)
Frontend	React 18, Tailwind CSS, shadcn/ui, Leaflet maps
Database	PostgreSQL 16.11
ORM	Prisma 5.10 (parameterized queries)
Authentication	NextAuth.js 4.24 (JWT, bcrypt)
Validation	Zod 3.25
Hosting	AWS EC2 t2.micro, Ubuntu 22.04, Nginx, PM2
CDN / WAF	Cloudflare (Full Strict TLS, HSTS, DDoS)

1.3 User Roles (Actors)

ID	Actor	Type	Description
E1	Registered Customer	Human	Books tickets with phone + password account
E2	Guest Customer	Human	Books without registration; phone = identity
E3	Company Admin	Human	Manages trips, staff, vehicles, fleet for one company
E4	Super Admin	Human	i-Ticket platform administrator with full access
E5	Driver	Human	GPS tracking, trip departure management
E6	Conductor	Human	Ticket QR scanning, boarding verification
E7	Cashier	Human	Manual/cash ticket sales, replacement tickets
E8	Mechanic	Human	Vehicle inspections, work orders
E9	Finance Staff	Human	Financial reports, cost tracking
E10	Sales Person	Human	Referral marketing, commission tracking
E11	Platform Staff	Human	i-Ticket support/operations (fine-grained permissions)
S1	TeleBirr	External System	Mobile money payment gateway (Ethio Telecom)
S2	SMS Gateway	External System	Ticket delivery via Negarit/GeezSMS
S3	Telegram Bot API	External System	Bilingual booking via @i_ticket_busBot

2. Software Requirements Specification (SRS)

2.1 Functional Requirements

FR-01: Authentication & Authorization

- Multi-role authentication: Customer, Company Admin, Super Admin, and 6 staff sub-roles (Driver, Conductor, Cashier, Mechanic, Finance, Sales)
- Credentials provider (NextAuth.js): phone + bcrypt password (12 salt rounds)
- JWT sessions: httpOnly cookie, 30-day expiry, SameSite=lax
- Login rate limiting: 5 attempts per phone per 30 min; 10 per IP per 15 min
- Registration: 3 per hour per IP; phone format validated (`/^09\d{8}$/`)
- Force-password-change flag for staff created with temporary passwords
- Password reset via SMS token (bcrypt-hashed, 1-hour expiry, single-use)

FR-02: Trip Management

- Company admins create, update, and cancel trips with origin/destination cities, departure time, total seats, price, and vehicle/staff assignments
- Trips follow a lifecycle: `DRAFT → SCHEDULED → BOARDING → DEPARTED → COMPLETED / CANCELLED`
- Intermediate stops: each trip can have named pickup/dropoff waypoints with lat/lon
- Trip templates: reusable configurations for recurring routes

- Auto-halt: online booking halts when available seats ≤10 (configurable bypass per company or trip)
- View-only enforcement: DEPARTED/COMPLETED/CANCELLED/SOLD-OUT trips are read-only

FR-03: Booking & Ticketing

- Real-time seat selection with 10-minute payment window (row-level locking on seat reservation)
- Multi-passenger bookings: up to 5 passengers per booking
- Guest booking: no registration required; phone number collected at checkout
- QR-coded tickets and alphanumeric shortcodes for each passenger
- Auto-generate manifests on trip departure or full capacity

FR-04: Payment Processing

- TeleBirr mobile money integration (HMAC-SHA256 signed API requests)
- Payment breakdown shown before confirmation: ticket price + 5% commission + 15% VAT
- TeleBirr fee (0.5%) absorbed by i-Ticket, invisible to customers
- 10-minute payment timeout enforced server-side with automatic seat release
- 5-gate callback verification (see Section 5.2)
- Demo mode for testing (blocked in NODE_ENV=production)

FR-05: Fleet Management

- Vehicle registry with make, model, plate, insurance/registration expiry tracking
- Pre-trip, daily, weekly, annual, and safety vehicle inspections
- Work orders for repairs with parts and labor tracking
- AI risk scoring (0–100) per vehicle, updated daily by cron job
- Pre-departure safety check: vehicles with risk score ≥ 85 require recent inspection before trip departure
- Fleet analytics dashboard: health gauges, risk trends, cost forecasts, failure timelines, TCO

FR-06: GPS Tracking

- Driver browser-based GPS: position sent every 10 seconds via authenticated API
- OsmAnd background GPS: tokenized GET endpoint for persistent background tracking (no session needed)
- Passenger live map: polls bus position every 12 seconds for DEPARTED trips
- Company fleet map: all active buses on one map, 15-second polling
- OSRM road route overlay replaces straight-line path
- ETA calculation: Haversine distance ÷ avg speed × 1.3 road-winding factor
- GPS data auto-purged after 7 days for completed/cancelled trips
- Telegram `/whereismybus`: shows live GPS location and ETA

FR-07: No-Show Management

- Boarding checklist per trip: all passengers with status PENDING / BOARDED / NO_SHOW
- No-show marking: only allowed after trip DEPARTED; idempotent re-marking
- Replacement ticket sales: same seat price, cash only, staff/cashier roles, commission = 0
- `availableSlots` unchanged by no-show/replacement (prevents online booking confusion)
- Replacement cap: cannot sell more replacements than `releasedSeats` counter

FR-08: Telegram Bot (@i_ticket_busBot)

- Bilingual (English + Amharic) booking flow via Telegram inline keyboards
- 11-step booking wizard: language → phone verification → origin → destination → date → trip → passengers → seats → passenger details → payment → confirmation
- Fuzzy city search (Levenshtein distance) for typo tolerance
- Tickets sent as Telegram messages + SMS; QR codes included
- `/whereismybus`: live GPS tracking link for departed trips

FR-09: Reports & Analytics

- Excel exports: maintenance costs, vehicle TCO, downtime, fleet analytics
- Revenue reports, tax reports (VAT), manifest downloads
- Admin: platform-wide booking analytics, top routes, monthly trends

2.2 Non-Functional Requirements

NFR-01: Security

- OWASP Top 10 (2021) addressed (see Section 6)
- TLS 1.2+ enforced at Cloudflare edge (Full Strict mode)
- HSTS: `max-age=31536000; includeSubDomains; preload`
- CSP via Next.js middleware; violations reported to `/api/csp-report`
- Rate limiting at three layers: Cloudflare → Nginx (30 req/s per IP) → Application (per-endpoint)
- Passwords: bcrypt (12 rounds); never stored in plaintext
- Company data segregation: every company API filters by `companyId` from JWT

NFR-02: Performance

- API response target: < 2 seconds under normal load
- Nginx rate limiting: 30 req/s per IP for API routes
- Cloudflare CDN caches static assets at edge
- PM2 cluster mode with auto-restart on crash or memory threshold (800 MB)
- PostgreSQL on localhost (Unix socket, no network latency)

NFR-03: Availability

- PM2 auto-restart on crash (max 10 restarts, 10s min uptime)
- Daily PM2 restart at 03:00 UTC for memory management
- Cloudflare proxies traffic; origin downtime partially shielded by edge cache
- Cron cleanup every 15 minutes prevents data accumulation issues

NFR-04: Scalability

- Stateless Next.js application (horizontal scaling ready)
- Prisma connection pooling
- Cloudflare CDN offloads static assets globally

NFR-05: Compliance

- Ethiopian VAT (15%) applied to platform commission
- Passenger manifests generated per transport authority requirements
- Vehicle safety inspections tracked; compliance calendar for upcoming due dates
- Payment processed by TeleBirr (licensed NBE payment service provider)

NFR-06: Data Integrity

- Row-level locking: `SELECT FOR UPDATE NOWAIT` on booking/seat operations
- Transaction timeouts: 10-second dual timeout (Promise.race + Prisma native)
- Zod validation on all API inputs (server-side; client validation is UX only)
- Server-side payment amount recalculation (client amounts never trusted)
- Idempotency: `ProcessedCallback` table prevents payment replay

3. System Architecture

3.1 Deployment Architecture

```
+-------------------------------------------------------------+
|                        INTERNET                             |
|  Customers, Drivers, Staff, TeleBirr, Telegram, OsmAnd       |
+----------------------------+--------------------------------+
                             | DNS: i-ticket.et
                             |
+----------------------------+--------------------------------+
|              CLOUDFLARE CDN / WAF                            |
|  SSL: Full Strict, TLS 1.2+, HSTS preload                    |
|  DDoS Protection (automatic), Web Analytics                  |
|  Email Obfuscation: DISABLED (breaks React hydration)        |
+----------------------------+--------------------------------+
                             | HTTPS to origin (Cloudflare cert)
                             |
+----------------------------+--------------------------------+
|           AWS EC2 t2.micro (54.147.33.168)                   |
|           Ubuntu 22.04 LTS, us-east-1                        |
|                                                              |
|  +-----------------------------------------------------+  |
|  |  NGINX (Port 80)                                    |  |
|  |  Rate limit: 100 req/min general, 30 req/s API      |  |
|  |  server_tokens off, headers stripped, max_body 5MB  |  |
|  +----------------------------+------------------------+  |
|                               |                              |
|  +----------------------------+------------------------+  |
|  |  PM2 PROCESS MANAGER                                |  |
|  |  App: i-ticket, Cluster mode, Max memory: 800MB     |  |
|  |  Auto-restart, cron restart 03:00 UTC               |  |
|  +----------------------------+------------------------+  |
|                               |                              |
|  +----------------------------+------------------------+  |
|  |  NODE.JS 20 / NEXT.JS 14 (Port 3000)               |  |
|  |  Middleware: CSP headers, Cache-Control: no-store    |  |
|  |  API Routes: Zod validation, rate limiting, RBAC     |  |
|  |  NextAuth: JWT sessions, bcrypt, rate-limited login  |  |
|  +----------------------------+------------------------+  |
|                               |                              |
|                        Prisma ORM (parameterized)            |
|                               |                              |
|  +----------------------------+------------------------+  |
|  |  POSTGRESQL 16.11 (localhost:5432, Unix socket)     |  |
|  |  39 tables, row-level locking, 10s transaction timeouts |  |
|  +-----------------------------------------------------+  |
|                                                              |
+-------------------------------------------------------------+
```

3.2 Component Architecture

```
+=========================+=========================+
|    FRONTEND (React 18)  |    BACKEND (API Routes) |
|                         |                         |
|  App Router Pages:      |  /api/auth/*            |
|   /(auth)   Login/Register |  /api/trips           |
|   /(customer) Booking/Track|  /api/bookings        |
|   /(company) Dashboard  |  /api/payments/*        |
|   /(admin)  Platform    |  /api/tickets/verify    |
|   /(driver) GPS Tracking |  /api/tracking/*       |
|   /(staff)  Operations  |  /api/company/*         |
|   /(cashier) Sales      |  /api/admin/*           |
|   /(mechanic) Fleet     |  /api/telegram/webhook  |
|   /(finance) Reports    |  /api/cron/*            |
|                         |  /api/csp-report        |
|  Libraries:             |                         |
|   Leaflet (maps)        |  Shared lib/:           |
|   Recharts (analytics)  |   auth.ts  (NextAuth)   |
|   shadcn/ui (components) |  db.ts    (Prisma)    |
|   date-fns              |   rate-limit.ts         |
+=========================+   payments/telebirr.ts  |
                          |   telegram/bot.ts       |
                          |   tracking/update-pos.ts |
                          |   ai/predictive-maint.ts |
                          +=========================+
                                     |
                          Prisma ORM (parameterized)
                                     |
                          PostgreSQL 16.11 (39 tables)
```

3.3 External Service Integrations

Service	Protocol	Auth	Direction
TeleBirr API	HTTPS REST	HMAC-SHA256 (APP_KEY)	Outbound + Inbound callback
SMS Gateway (Negarit)	HTTPS REST	Bearer token	Outbound; inbound HMAC webhook
Telegram Bot API	HTTPS webhook	Bot token / Telegram-signed	Bidirectional
OSRM Routing	HTTPS REST	None (public)	Outbound
Nominatim Geocoding	HTTPS REST	None (public)	Outbound
OpenStreetMap Tiles	HTTPS CDN	None (public)	Client-side
ClickUp	HTTPS REST	API token	Outbound (support tickets)
Cron Scheduler	HTTPS GET	Bearer (CRON_SECRET)	Inbound
OsmAnd GPS App	HTTPS GET	Trip tracking token	Inbound

3.4 Security Layers (Defense in Depth)

Layer	Component	Controls
L1: Edge	Cloudflare	TLS 1.2+, HSTS preload, DDoS protection, origin cert
L2: Network	Nginx	Rate limiting (30r/s API), server_tokens off, max body 5MB
L3: Middleware	Next.js middleware.ts	CSP headers, Cache-Control: no-store, violation reporting
L4: App Headers	next.config.js	HSTS, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy
L5: Auth	NextAuth.js	JWT (30d), bcrypt(12), rate-limited login, company segregation
L6: Validation	Zod schemas	All API inputs; server-side amount recalculation
L7: Payment	TeleBirr module	HMAC-SHA256, timing-safe compare, 5-gate callback, replay table
L8: Database	Prisma + PostgreSQL	Parameterized queries, row-level locking, transaction timeouts
L9: Audit	AdminLog table	All sensitive operations logged with actor, action, timestamp

4. Data Flow Diagrams

4.1 Level 0 — Context DFD

```
                              +-----------+
                              | Cloudflare|
                              |  CDN/WAF  |
                              +-----+-----+
                                    | HTTPS/TLS 1.2+
                                    |
+-----------+  Search/Book  +-----+-----+  Payment Req   +---------+
| Customer  |-------------->|           |-------------->| TeleBirr|
| (E1/E2)   |<--------------| i-Ticket  |<--------------| (S1)    |
+-----------+  Tickets/QR   | Platform  |  Callback     +---------+
                            |           |
+-----------+ Manage Trips  |           |  SMS          +---------+
| Company   |-------------->|           |-------------->| SMS Gwy |
| Admin (E3)|<--------------| (P0)      |<--------------| (S2)    |
+-----------+ Reports/Data  |           |  Inbound SMS  +---------+
                            |           |
+-----------+ Full Access   |           |  Bot Msg      +---------+
| Super     |-------------->|           |-------------->| Telegram|
| Admin (E4)|<-------------             |<--------------| (S3)    |
+-----------+ Dashboard     |           |  Webhook      +---------+
                            |           |
+-----------+ GPS Location  |           |  Tracking     +---------+
| Driver    |-------------->|           |<--------------| OsmAnd  |
| (E5)      |<-------------             |               | (S12)   |
+-----------+ Trip Status   |           |               +---------+
                            |           |
+-----------+ Scan/Board    |           |  Cron Trigger +---------+
| Conductor |-------------->|           |<--------------| Cron    |
| (E6)      |<-------------             |               | (S14)   |
+-----------+ Verify Result |           |               +---------+
                            |           |
+-----------+ Sell Tickets  |           |
| Cashier   |-------------->|           |
| (E7)      |<-------------             |
+-----------+ Ticket/QR    |            |
                            |           |
+-----------+ Inspections   |           |
| Mechanic  |-------------->|           |
| (E8)      |<-------------             |
+-----------+ Work Orders   +-----+-----+
                                  |
                              Prisma ORM
                                  |
                        +---------+---------+
                        | PostgreSQL 16     |
                        | 39 tables         |
                        +-------------------+
```

4.2 Level 1 — Core Business Processes

```
+-------------------------------------------------------------------------+
|                        i-Ticket Platform                                |
|                                                                         |
|  +-----------------+   +-----------------+   +--------------------+ |
|  | P1: Auth &      |   | P2: Trip Search |   | P3: Payment        | |
|  | Session Mgmt    |   | & Booking       |   | Processing         | |
|  | - bcrypt login  |   | - Seat locking  |   | - TeleBirr initiate| |
|  | - JWT cookies   |   | - Guest booking |   | - 5-gate callback  | |
|  | - Rate limiting |   | - Auto-halt     |   | - Ticket issuance  | |
|  +-----------------+   +-----------------+   +--------------------+ |
|                                                                         |
|  +-----------------+   +-----------------+   +--------------------+ |
|  | P4: GPS         |   | P5: No-Show &   |   | P6: Fleet Mgmt     | |
|  | Tracking        |   | Replacement     |   | & Maintenance      | |
|  | - Driver GPS    |   | - Boarding list |   | - Risk scoring     | |
|  | - OsmAnd token  |   | - Mark NO_SHOW  |   | - Inspections      | |
|  | - Passenger map |   | - Sell replace  |   | - Work orders      | |
|  +-----------------+   +-----------------+   +--------------------+ |
|                                                                         |
|  +-----------------+   +-----------------+   +--------------------+ |
|  | P7: Telegram Bot |   | P8: Cron Jobs   |   | P9: Admin Platform | |
|  | - Booking wizard |   | - Pay timeout   |   | - All companies    | |
|  | - GPS tracking   |   | - Trip status   |   | - Tax reports      | |
|  | - Ticket view    |   | - AI risk score |   | - Audit logs       | |
|  +-----------------+   +-----------------+   +--------------------+ |
+-------------------------------------------------------------------------+
```

4.3 Level 2 — TeleBirr Callback (Payment Security Detail)

```
S1 (TeleBirr) ──> POST /api/payments/telebirr/callback
                  Body: { transactionId, totalAmount, tradeStatus,
                          signature, timestamp, nonce }
                            |
                  +---------+---------+
                  | GATE 1: Compute   |
                  | SHA-256(payload)  |
                  | (callbackHash)    |
                  +---------+---------+
                            |
                  +---------+---------+
                  | GATE 2: Replay    |
                  | Check ProcessedCallback|
                  | by transactionId  |
                  | Found --> 200 (idempotent)|
                  +---------+---------+
                            |
                  +---------+---------+
                  | GATE 3: HMAC Sig  |
                  | HMAC-SHA256(payload, APP_KEY)|
                  | timingSafeEqual() |
                  | Fail --> 403      |
                  +---------+---------+
                            |
                  +---------+---------+
                  | GATE 4: Timestamp |
                  | |now - ts| < 5min |
                  | (log warning, continue)|
                  +---------+---------+
                            |
                  +---------+---------+
                  | GATE 5: IP Check  |
                  | (if TELEBIRR_IPS  |
                  |  env is set)      |
                  +---------+---------+
                            |
                  +---------+---------+
                  | TRANSACTION (10s) |
                  | SELECT Booking    |
                  |   FOR UPDATE NOWAIT|
                  | IF SUCCESS:       |
                  |   status=PAID     |
                  |   Create Tickets  |
                  |   ProcessedCallback|
                  |   Commission      |
                  | IF FAIL:          |
                  |   status=CANCELLED|
                  |   Release seats   |
                  +---------+---------+
                            |
                  Send ticket SMS + AdminLog
```

4.4 Data Stores

Store	Name	Sensitivity
D1	User	HIGH (bcrypt password)
D2	Company	HIGH (bankAccount, tinNumber)
D3	Trip	MEDIUM
D4	Booking	HIGH (financial amounts)
D5	Passenger	HIGH (nationalId, phone)
D6	Ticket	HIGH (QR + shortCode)
D7	Payment	HIGH (transactionId, amounts)
D9	Vehicle	MEDIUM
D17	VehicleRiskHistory	LOW
D19	TripPosition	MEDIUM (location) — purged 7 days
D28	TelegramSession	MEDIUM — 30-min expiry
D35	AdminLog	HIGH (audit trail)
D36	ProcessedCallback	HIGH (payment replay guard)

4.5 Trust Boundaries

```
+==================================================================+
|  UNTRUSTED INTERNET                                              |
|  Customers, Guests, TeleBirr callbacks, Telegram webhooks,      |
|  OsmAnd GPS, SMS webhooks, Cron triggers                        |
+====================+=============================================+
                     | HTTPS/TLS 1.2+ - Cloudflare HSTS
+====================+=============================================+
|  CLOUDFLARE EDGE - SSL termination, DDoS, WAF                    |
+====================+=============================================+
                     | HTTPS to origin cert
+====================+=============================================+
|  NGINX - Rate limiting, header stripping                         |
+====================+=============================================+
                     | localhost:3000
+====================+=============================================+
|  APPLICATION (Node.js) - Auth checks, Zod validation, RBAC      |
|  Company segregation, rate limits, CSP headers                   |
|  Authenticated users: E3-E11 (all staff roles)                  |
+====================+=============================================+
                     | Prisma ORM (parameterized queries only)
+====================+=============================================+
|  DATABASE - PostgreSQL 16, localhost only, row-level locking     |
+==================================================================+
```

5. Business Logic Interactions

5.1 Trip Lifecycle State Machine

```
[DRAFT] ———(admin activates)———→ [SCHEDULED]
                                        |
              (30 min late, no depart)  |   (boarding begins)
                      |                 v
             [DELAYED] ←————————— [BOARDING]
                                        |
              (past departure time, auto)|
                                        v
                                  [DEPARTED]  ←—— (driver GPS active)
                                        |
                      +——————————————————+——————————————————+
                      |                                     |
           (past ETA + 2hr, auto)              (admin/cron cancels)
                      |                                     |
                      v                                     v
                 [COMPLETED]                           [CANCELLED]

Guards:
  DRAFT → SCHEDULED: vehicle + driver + conductor assigned
  BOARDING: booking stays open, manual sales allowed
  DEPARTED: bookingHalted=true, no online booking; staff ON_TRIP
  COMPLETED: trackingActive=false; staff AVAILABLE; manifest auto-generated
  CANCELLED: availableSlots restored; pending payments refunded
```

5.2 Booking & Payment Flow

```
1. Seat Reservation
   Customer → POST /api/bookings
   → SELECT Trip FOR UPDATE NOWAIT (row lock)
   → Decrement availableSlots
   → Create Booking (status=PENDING, 10-min window)
   → Release lock

2. Auto-Halt Check
   IF availableSlots ≤ 10 AND !disableAutoHaltGlobally AND !autoResumeEnabled:
     Trip.bookingHalted = true (blocks new online bookings)
     Notify company admin

3. Payment Initiation
   Customer → POST /api/payments { bookingId, method: TELEBIRR }
   → Verify: booking belongs to user, within 10-min window
   → Recalculate amount server-side (price + 5% commission + 15% VAT)
   → HMAC-SHA256 sign request → TeleBirr API
   → Return MMI popup URL to customer

4. Payment Confirmation
   TeleBirr → POST /api/payments/telebirr/callback
   → 5-gate verification (Section 4.3)
   → Transaction: Booking=PAID, Tickets created, Commission logged
   → SMS + Telegram ticket delivery

5. Timeout Cleanup (Cron, every 15 min)
   PENDING bookings older than 10 min → CANCELLED
   availableSlots restored
   Timeout SMS sent to customer
```

5.3 Auto-Halt Rule

```
CONDITION: availableSlots ≤ 10 after any booking creation

IF Company.disableAutoHaltGlobally = true  → no halt (all trips)
IF Trip.autoResumeEnabled = true           → no halt (this trip)
ELSE                                       → Trip.bookingHalted = true

MANUAL SALES EXCEPTION:
  Cashier/Staff manual ticket sales → NEVER blocked by auto-halt
  Manual sales can proceed to 0 available slots
  (Manual sales track: manualTicketsSold counter, separate from online)
```

5.4 No-Show Management & Seat Re-Sale

```
PRECONDITION: Trip.status == DEPARTED

Step 1: Mark No-Shows
  POST /api/company/trips/[id]/no-show
  { passengerIds: [...] }
  → Guard: ticket not already scanned (isUsed=false)
  → Guard: passenger not already BOARDED
  → Passenger.boardingStatus = NO_SHOW
  → Trip.noShowCount++, Trip.releasedSeats++
  → AdminLog: PASSENGER_NO_SHOW

Step 2: Sell Replacement Tickets
  POST /api/company/trips/[id]/replacement-ticket
  { name, phone, [seatNumber] }
  → Guard: Trip.releasedSeats > 0
  → Assign no-show seat number
  → Create Booking (isReplacement=true), Passenger (BOARDED), Ticket+QR, Payment (CASH)
  → Trip.replacementsSold++, Trip.releasedSeats--
  → AdminLog: REPLACEMENT_TICKET_SALE

NOTE: availableSlots is NEVER modified during no-show/replacement flow.
      Seats were already counted as sold. Online booking counts are unaffected.
```

5.5 Company Data Segregation (Rule RULE-001)

Every company-scoped API route enforces this pattern without exception:

```
// Pseudocode — pattern in every /api/company/* route handler
const session = await getServerSession(authOptions)
if (!session || session.user.role !== "COMPANY_ADMIN") return 401/403

const companyId = session.user.companyId   // From verified JWT

const trips = await prisma.trip.findMany({
  where: { companyId }   // Enforced DB filter — cannot see other companies
})
```

Only exception: The `City` table is shared read-only reference data across all companies.

5.6 Commission & VAT Calculation

```
For each online TeleBirr booking:

  ticketPrice   = base fare (set by company)
  commission    = ticketPrice × 0.05        (5% platform fee)
  vat           = commission × 0.15         (15% VAT on commission)
  telebirrFee   = totalAmount × 0.005       (0.5%, absorbed by i-Ticket)
  customerPays  = ticketPrice + commission + vat
  companyReceives = ticketPrice             (after platform deduction)

For manual (cashier) sales:
  commission = 0  (no platform fee for cash transactions)
  companyReceives = full ticket price

For replacement ticket sales:
  commission = 0  (same as cashier pattern)
```

6. Threat Modeling

6.1 Attack Surface

Surface	Exposure	Auth	Notes
Trip search API	Public	None	Read-only; Nginx rate-limited
Booking creation	Public (guest)	Optional	Rate-limited 10/min/IP
Payment initiation	Authenticated	JWT session	Rate-limited 3/hr/booking
TeleBirr callback	Internet	HMAC signature	5-gate verification
Telegram webhook	Internet	Telegram-signed	Bot token verified
GPS tracking (driver)	Authenticated	JWT session	Rate-limited 12/min/user
GPS tracking (OsmAnd)	Internet	Trip tracking token	Rate-limited 12/min/token
Ticket verification	Authenticated	JWT (staff roles)	Audit logged
Admin portals	Authenticated	JWT (SUPER_ADMIN)	All operations logged
Company portals	Authenticated	JWT (COMPANY_ADMIN)	companyId enforced
Cron endpoints	Internet	Bearer CRON_SECRET	Read-only DB operations

6.2 STRIDE Threat Analysis

Threat	Component	Example Attack	Mitigation
Spoofing	Login endpoint	Credential stuffing, brute force	bcrypt(12), rate limit 5/30min/phone, 10/15min/IP
Spoofing	TeleBirr callback	Fake payment callbacks	HMAC-SHA256 signature verification (Gate 3), IP whitelist (Gate 5)
Spoofing	JWT session	Session token theft	httpOnly cookie (no JS access), secure flag, SameSite=lax
Tampering	Payment amount	Client sends lower price	Server recalculates amount independently; client amount ignored
Tampering	Booking data	Modify another user's booking	Ownership check: booking.userId must match session.userId
Tampering	Trip data	Company edits another company's trip	companyId filter on all writes; RBAC enforcement
Repudiation	Disputed payments	"I never received a ticket"	AdminLog, ProcessedCallback table, SMS delivery record
Repudiation	Boarding disputes	"I was marked no-show unfairly"	AdminLog: PASSENGER_NO_SHOW with userId + timestamp
Information Disclosure	Cross-company data	Company A reads Company B's trips	companyId filter enforced in every company API route
Information Disclosure	Passenger PII	Expose nationalId or phone	API responses filtered; ticket verify hides bookedByPhone
Denial of Service	API flooding	Brute-force or bot traffic	Cloudflare DDoS, Nginx 30r/s limit, application rate limits
Denial of Service	Payment timeout	Hold booking then abandon	10-min payment window + cron release of timed-out bookings
Elevation of Privilege	Role escalation	Customer calls company admin API	Role check in every protected API route; `companyId` from JWT
Elevation of Privilege	Company cross-access	Company admin accesses rival data	companyId hard-set from JWT; cannot be user-supplied
Elevation of Privilege	Staff role abuse	Driver accesses company admin features	`staffRole` checked separately from main `role`; scope-limited APIs

6.3 Key Security Controls

Vulnerability	Control	Implementation
SQL Injection	Prisma ORM exclusively	Zero raw SQL in codebase; all queries parameterized
XSS	React auto-escaping + CSP	No `dangerouslySetInnerHTML`; CSP blocks inline scripts from external origins
CSRF	SameSite=lax cookie + CSP form-action	Cross-origin POST requests don't carry the session cookie
Clickjacking	X-Frame-Options: DENY	`frame-ancestors 'none'` in CSP; X-Frame-Options header
IDOR	companyId + ownership checks	Every resource access verifies ownership from JWT, not URL params
Replay Attack	ProcessedCallback table	Unique index on transactionId; idempotent callback processing
Brute Force	Multi-layer rate limiting	5/30min per phone, 10/15min per IP; 429 with Retry-After
Timing Attack	crypto.timingSafeEqual()	HMAC comparison uses constant-time function
Stale Secrets	Startup validation	NEXTAUTH_SECRET >= 32 chars; placeholder values rejected at boot
Race Condition	SELECT FOR UPDATE NOWAIT	DB-level row lock prevents double-seat-selling
Path Traversal	Generated filenames	Upload filenames are system-generated IDs, not user-supplied
MIME Sniffing	X-Content-Type-Options: nosniff	Prevents browser from guessing content types

6.4 Known Gaps and Remediation Plan

Gap	Risk Level	Remediation
No field-level encryption for nationalId, bankAccount at rest	Medium	AES-256 encryption for sensitive DB fields
No database encryption at rest (AWS EBS)	Medium	Enable EBS encryption on storage volume
No MFA for admin accounts	Medium	TOTP-based MFA for SUPER_ADMIN and COMPANY_ADMIN
`unsafe-inline` in CSP script-src	Low	Upgrade to Next.js 15+ for nonce-based CSP
No JWT revocation mechanism	Low	Implement token version counter in User table
No centralized SIEM integration	Low	Forward AdminLog to centralized security monitoring
No automated security alerts	Low	Alert rules for login spikes, unusual API volume

6.5 OWASP Top 10 Compliance Summary

OWASP Category	Status	Notes
A01 Broken Access Control	Mitigated	RBAC, companyId segregation, ownership checks
A02 Cryptographic Failures	Partially Mitigated	TLS 1.2+, bcrypt, HMAC-SHA256; gap: no DB encryption at rest
A03 Injection	Mitigated	Prisma ORM (zero raw SQL), Zod validation, React escaping
A04 Insecure Design	Mitigated	Rate limits, server-side amounts, row locking, threat model
A05 Security Misconfiguration	Mitigated	Security headers, error handling, no default creds
A06 Vulnerable Components	Mitigated	Node 20 LTS, PG 16, Ubuntu 22.04; Dependabot scanning
A07 Auth Failures	Partially Mitigated	bcrypt, rate limiting, httpOnly JWT; gap: no MFA
A08 Data Integrity Failures	Mitigated	HMAC callbacks, lockfile, server-side recalculation
A09 Logging & Monitoring	Partially Mitigated	AdminLog, PM2 logs, CSP reports; gap: no SIEM
A10 SSRF	Mitigated	No user-controlled URLs; all external APIs hardcoded

7. Testing Scope & Credentials

7.1 Web Portals in Scope

#	Portal	URL	Description
1	Public Web Portal	https://i-ticket.et	Search, book, pay, track
2	Admin Dashboard	https://i-ticket.et/admin/*	Platform management
3	Company Portal	https://i-ticket.et/company/*	Trip, staff, fleet management
4	Driver Portal	https://i-ticket.et/driver/*	GPS tracking
5	Cashier Portal	https://i-ticket.et/cashier/*	Manual ticket sales
6	Mechanic Portal	https://i-ticket.et/mechanic/*	Vehicle inspections, work orders
7	Finance Portal	https://i-ticket.et/finance/*	Financial reports
8	Sales Portal	https://i-ticket.et/sales/*	Referral dashboard
9	REST API	https://i-ticket.et/api/*	All backend endpoints (~84 routes)
10	Telegram Bot	https://t.me/i_ticket_busBot	@i_ticket_busBot
11	TeleBirr Callback	https://i-ticket.et/api/payments/telebirr/callback	Payment webhook
12	Origin Server	54.147.33.168	Direct (bypasses Cloudflare)

7.2 Test Account Credentials

Role	Phone	Password	Portal	Scope
Super Admin	0911223344	demo123	/admin/*	Full platform: all companies, analytics, audit logs, tax reports
Company Admin (Selam Bus)	0922345678	demo123	/company/*	Full company: trips, staff, vehicles, fleet analytics, boarding
Customer	0912345678	demo123	/	Search, book, tickets, tracking
Guest Customer	Any 09XXXXXXXX	N/A	/	Book without registration

Staff sub-role accounts (Driver, Conductor, Cashier, Mechanic, Finance) can be created via the Company Admin portal under Staff Management.

7.3 Out of Scope

Item	Reason
AWS EC2 OS/kernel internals	Infrastructure-level audit (separate scope)
Cloudflare configuration internals	Managed CDN service
PostgreSQL server engine	Database-level audit (separate scope)
TeleBirr, SMS Gateway, Telegram API internals	Third-party services
DDoS testing	Risk to production availability
Social engineering	Not in scope for web application audit
Production payment processing	Use DEMO_MODE test flow only

7.4 Testing Environment Note

There is no separate staging environment. All testing is performed on the production instance (https://i-ticket.et) using the test accounts above. Test accounts are isolated from real customer data. DEMO_MODE=true simulates TeleBirr payments without real money movement.

8. Contact Information

8.1 i-Ticket Team

Name	Role	Contact
Abel Assefa	General Manager / Platform Owner	+251 911 550 001
Solomon Gemechu	CFO / Finance Lead	Available upon request

8.2 INSA Audit Division

Name	Role	Contact
Dr. Tilahun Ejigu	INSA Cyber Security Audit	tilahune@insa.gov.et
		+251 937 456 374

8.3 Submission Reference

- **Request ID**: ICAER-2026-E391DA
- **Previous Submission**: 17-document, 183-page package (February 2026)
- **This Resubmission**: Single consolidated document per INSA Requirements Notice
- **Covers**: SRS, Data Flow, System Architecture, Business Logic, Threat Modeling, Functional and Non-Functional Requirements

---

End of Document — ICAER-2026-E391DA Resubmission i-Ticket Platform v2.14.5 | February 2026